



ENTERPRISE AI CONTEXT CONTROL PLANE

Nomad Product Requirements Document

A governed context layer for people, organizations, and the AI tools they choose.

VERSION	STATUS
2.0	Direction approved Experience validation in progress

Contents

1. Executive summary	3
2. Product decision	3
3. Problem	3
4. Target users and buyers	4
5. Jobs to be done	4
6. Product principles	5
7. Product model	5
8. User experience and information architecture	7
9. Functional requirements	7
10. Initial integration scope	9
11. Security and privacy requirements	9
12. Non-functional requirements	10
13. Success measures	10
14. Commercial hypothesis	10
15. Milestone gates	11
16. Out of scope for the first production pilot	12
17. Key risks and responses	13
18. Open decisions requiring validation	13
19. Current project record	14
20. References	14
Interface directions	16

Version: 2.0

Status: Product direction approved; experience validation in progress

Product category: Enterprise AI Context Control Plane

Replaces: Nomad PRD v1.0

1. Executive summary

Nomad gives organizations and their employees one governed place to control which approved context each AI assistant may read, propose, update, retain, and export.

The product is not another general-purpose AI memory database. It is a policy and evidence layer that sits between people, organizations, and AI tools. Nomad stores typed context passports, evaluates access against deterministic policies, captures user approval where required, and produces evidence for every read and write.

The first commercial wedge is an enterprise using more than one AI assistant and needing consistent employee context without allowing unrestricted context sharing between vendors, projects, or clients.

2. Product decision

Previous framing

The original concept positioned Nomad as a universal, portable memory layer shared across AI products.

Updated framing

Portable memory is now an active and increasingly crowded category. Nomad therefore competes on governance rather than memory retrieval.

Nomad is the enterprise control plane for portable AI context.

Connectivity is provided through standards such as MCP and vendor tool APIs. Nomad's differentiated work is authorization, policy, provenance, consent, isolation, revocation, and audit evidence.

3. Problem

Enterprises increasingly operate a multi-vendor AI stack. Employees repeat preferences, project facts, terminology, constraints, and working conventions in each tool. Copying that context manually is inefficient, but sharing it automatically creates security and privacy risk.

Organizations lack a consistent answer to five questions:

1. What context about an employee, project, or client exists?
2. Who owns it and where did it come from?
3. Which AI tool may use it, for what purpose, and for how long?
4. Who approved a change or disclosure?

5. Can the organization prove, revoke, export, or delete that access?

Vendor-native memory settings answer only a portion of these questions and do so separately inside each vendor boundary.

4. Target users and buyers

Economic buyer

VP of Enterprise AI / CIO delegate - accountable for adoption, cost, governance, and measurable value across a multi-vendor AI portfolio.

Technical champion

Staff AI Platform Engineer - integrates approved tools and needs a reliable, standards-based context service without building separate policy logic for every assistant.

Control stakeholders

- **CISO / Security Architect** - needs least privilege, tenant isolation, revocation, and incident evidence.
- **Data Protection Officer / Privacy Counsel** - needs purpose limitation, retention, subject access, deletion, and defensible consent records.
- **Identity / SaaS Administrator** - needs SSO, provisioning, role management, and organization-wide connector controls.

Daily users

- **Knowledge worker / product manager** - wants useful personalization without repeatedly explaining preferences and projects.
- **Consultant or client-services professional** - needs hard separation between client contexts.
- **Internal AI application developer** - needs a stable context contract and clear authorization responses.

Internal delivery personas

- Associate AI Product Manager
- AI Product Analyst
- AI/ML Program Coordinator
- AI Solutions / Implementation Analyst

These personas shape how the project is prioritized, measured, documented, and introduced to pilot customers.

5. Jobs to be done

Employee

- When I use an approved AI assistant, give it only the context appropriate to my current organization, project, and task.
- Let me see, correct, expire, export, or revoke context associated with me.

- Ask me before a tool stores sensitive or materially new context.

Enterprise administrator

- Define which tools can access which context classes and purposes.
- Enforce boundaries between personal, organization, project, and client context.
- Investigate reads, proposed changes, approvals, denials, exports, and revocations.
- Apply retention and deletion policy consistently across integrations.

AI platform engineer

- Integrate once through MCP or REST instead of rebuilding memory governance for every agent.
- Receive deterministic authorization results and stable schemas.
- Separate model-generated proposals from committed context.

6. Product principles

1. **Context is governed data, not chat history.** Full transcripts are not stored by default.
2. **The user can see what the AI sees.** Rendered context is inspectable before and after access.
3. **Models propose; policy decides.** An LLM never grants itself access or commits sensitive context.
4. **Least privilege by field, purpose, scope, and time.** Broad permanent grants are not the default.
5. **Work and personal identities remain separate.** No silent movement across tenant or client boundaries.
6. **Every consequential action leaves evidence.** Reads, writes, approvals, denials, exports, and revocations are recorded.
7. **Open interfaces, portable data.** Customers can export their context and integrate through documented protocols.
8. **Useful without surveillance.** The product must not become an employee-monitoring system.

7. Product model

7.1 Context passport

A passport is a scoped collection of typed context fields. A person may have multiple passports.

Initial passport scopes:

- Personal
- Organization
- Project
- Client

Initial field families:

- Communication preferences

- Working conventions
- Role and responsibility
- Project facts and terminology
- Decisions and constraints
- Relationships and stakeholders
- Accessibility preferences
- Custom organization-defined fields

Every field includes:

- Identifier and schema version
- Human-readable value
- Owner and subject
- Scope and organization
- Source and provenance
- Sensitivity classification
- Allowed purposes
- Allowed tools or tool classes
- Created, reviewed, and expiration timestamps
- Confidence and verification state
- Version and supersession relationship

7.2 Access grant

An access grant permits a specific client to perform a defined operation on an allowed field set for a documented purpose and duration.

7.3 Context proposal

AI tools do not directly write trusted context. They submit proposals containing the candidate value, source, evidence, purpose, and requested scope. Policy either denies, auto-approves low-risk changes, or routes the proposal for human approval.

7.4 Policy

Policies are deterministic rules evaluated outside the model. They may reference tenant, user role, tool, operation, context scope, sensitivity, purpose, project, client, geography, and time.

7.5 Evidence event

Each read, proposal, approval, denial, change, export, revocation, or deletion creates an append-only evidence event. The event records the actor, client, policy decision, affected field identifiers, purpose, result, and integrity linkage. Sensitive values are not duplicated into the event stream.

8. User experience and information architecture

8.1 Employee workspace

Home - context health, connected tools, pending approvals, recent activity, and expiring grants.

My Passport - inspect and edit context by scope and category; view provenance, visibility, and expiration.

Access - see which AI tools can read or propose changes to each context class; revoke or narrow access.

Approvals - review proposed context changes and sensitive access requests with plain-language consequences.

Activity - searchable evidence timeline showing which tool accessed what, why, and under which policy.

Connections - connect or disconnect supported AI tools and view their capabilities.

8.2 Enterprise administrator workspace

Overview - adoption, integration health, policy coverage, risk exceptions, and unresolved approvals.

Policies - create and test context access rules using structured conditions rather than free-form prompts.

People and groups - provision users, assign roles, and apply group policies.

Integrations - approve connectors, configure OAuth clients, rotate credentials, and disable capabilities.

Evidence - investigate access events and export audit evidence.

Data lifecycle - retention, expiration, deletion, export, and legal-hold controls.

8.3 Primary interaction flow

1. An employee or administrator connects an approved AI tool.
2. The tool requests relevant context for a declared purpose and scope.
3. Nomad authenticates the client and evaluates policy.
4. Nomad returns only allowed fields in a purpose-specific rendering.
5. The tool may submit a proposed context update.
6. Nomad validates and classifies the proposal.
7. Low-risk proposals follow policy; sensitive proposals enter the approval inbox.
8. The final decision and resulting change create linked evidence events.
9. The employee or administrator can later revoke access, expire data, or export evidence.

9. Functional requirements

FR-1 Identity and tenancy

- Organization and user tenancy
- Strict tenant-bound queries and encryption context
- Role-based access for employee, reviewer, administrator, auditor, and service client
- Enterprise SSO before production pilot

- Provisioning and group sync before broad rollout

FR-2 Passport management

- Create, read, edit, archive, export, and delete passports
- Typed and versioned context fields
- Provenance, sensitivity, purpose, review state, and expiration metadata
- Optimistic concurrency and visible conflict handling
- No silent overwrite of verified context

FR-3 Policy and authorization

- Deny by default
- Per-operation authorization for every request
- Field-, scope-, purpose-, tool-, project-, and time-aware decisions
- Explainable allow, deny, and approval-required results
- Policy simulation before activation
- Emergency connector revocation

FR-4 Proposal and consent workflow

- Tools submit proposals rather than trusted writes
- Plain-language review showing old value, proposed value, source, and consequence
- Approve once, approve rule, edit and approve, or deny
- Sensitive categories always require explicit review unless an administrator has established a lawful alternative workflow
- Approval decisions are reversible where technically possible

FR-5 Evidence and audit

- Append-only evidence events
- Integrity chaining with externally anchored checkpoints before production pilot
- Search by actor, tool, action, policy, scope, outcome, and time
- Export in machine-readable and human-readable formats
- No sensitive plaintext copied into audit events

FR-6 Integration gateway

- Remote MCP server as the primary initial integration surface
- REST API for controlled internal integrations
- OAuth 2.1 authorization and audience-bound tokens

- Separate read and proposal tools
- Idempotency for mutations
- Rate limiting, retry behavior, and revocation

FR-7 Data lifecycle

- Field expiration and review reminders
- Tenant-defined retention rules
- User and administrator deletion workflows with documented authority boundaries
- Portable export of passport fields, policies applicable to the subject, and evidence metadata

10. Initial integration scope

First supported clients

1. Claude remote MCP connector
2. ChatGPT remote MCP integration
3. Generic MCP-compatible client for development and testing

Subsequent clients

- Gemini API remote MCP
- Microsoft Copilot Studio MCP
- Approved internal enterprise agents

Explicit limitation

Nomad does not claim direct synchronization with a vendor's private built-in memory. It operates as an external context sidecar invoked through supported tools and APIs.

Browser DOM scraping and silent transcript capture are excluded from the enterprise MVP because they are fragile, difficult to govern, and may violate platform or organizational expectations.

11. Security and privacy requirements

- TLS for all network communication
- Envelope encryption for sensitive field values
- Managed key lifecycle with rotation and tenant separation
- Secrets stored outside application configuration
- OAuth token rotation, expiration, revocation, and audience validation
- Server-side authorization on every request
- Prompt-injection-resistant boundaries: retrieved context is untrusted data, never executable policy

- Input and output schema validation
- DLP and sensitivity classification hooks
- Human approval for privileged or high-risk operations
- Tenant-isolation tests and negative authorization tests
- Data minimization in logs, analytics, and evidence events
- Incident-response runbook and connector kill switch
- Backup, restoration, deletion, and cryptographic-erasure procedures

12. Non-functional requirements

- **Availability:** graceful denial when policy or identity dependencies are unavailable; never fail open.
- **Performance:** authorization overhead measured separately from model latency; target set after pilot baseline.
- **Accessibility:** WCAG 2.2 AA for the web application.
- **Observability:** structured operational metrics without context values.
- **Portability:** documented schemas and complete customer export.
- **Maintainability:** modular monolith until scale demonstrates a need for service separation.
- **Deployability:** repeatable environments, automated migration checks, and rollback support.

13. Success measures

Targets will be set after discovery and baseline measurement. The product will measure:

- Repeated-context reduction per supported workflow
- Percentage of context reads allowed without over-broad grants
- Proposal approval, edit, and rejection rates
- Time required to answer "who accessed what and why"
- Revocation propagation time
- Context accuracy and stale-field rate
- Policy exception volume
- Active users across two or more approved AI tools
- Pilot renewal or expansion intent
- Security and privacy incidents attributable to context exchange

14. Commercial hypothesis

The initial customer hypothesis is a regulated or security-conscious organization that:

- Uses at least two AI assistants or agent platforms

- Has an internal AI platform, security, or governance owner
- Experiences repeated-context cost or inconsistent agent behavior
- Cannot permit unrestricted transcript sharing
- Will fund a controlled pilot to establish policy, evidence, and employee trust

This remains a hypothesis until validated through buyer interviews and design partners.

15. Milestone gates

Nomad uses outcome-based gates, not a fixed ten-week schedule. A milestone advances only when its evidence is complete.

Gate 0 - Product thesis and market correction - Complete

- Reviewed original PRD and architecture
- Validated major vendor portability and MCP capabilities
- Identified direct competitors and standards
- Repositioned from universal memory to enterprise context governance
- Defined buyer, champion, control stakeholders, and daily-user personas

Gate 1 - Experience and contract validation - In progress

- Revised PRD approved
- Three interface directions available for review
- Primary workflows and terminology confirmed
- Context field, proposal, grant, policy, and evidence contracts reviewed
- At least five customer discovery conversations completed before production scope is locked

Gate 2 - Trust foundation

- Tenant, identity, and authorization model implemented
- Context schema and versioning implemented
- Proposal workflow and append-only evidence implemented
- Threat model and abuse cases reviewed
- Automated tenant-isolation and negative-authorization tests passing

Gate 3 - Employee passport

- Employee home, passport, access, approvals, and activity experiences implemented
- Export, expiration, revocation, and deletion workflows working end to end
- Accessibility review passing

Gate 4 - Integration proof

- Generic MCP client passing contract tests
- Claude and ChatGPT integrations demonstrating controlled reads and proposals
- No native-memory synchronization claims
- Prompt-injection and excessive-agency tests passing

Gate 5 - Enterprise control plane

- Administrator policies, integrations, people/groups, evidence, and lifecycle controls implemented
- SSO and provisioning operational
- Policy simulation and connector kill switch tested

Gate 6 - Pilot readiness

- Deployment, backup, restore, monitoring, and incident response exercised
- Security and privacy review completed
- Pilot onboarding and support material complete
- Success baseline and pilot exit criteria agreed with a design partner

Gate 7 - Customer pilot

- One real organization uses two supported AI clients
- Pilot metrics and qualitative evidence collected
- Gaps prioritized from observed behavior rather than speculation
- Expansion, revision, or stop decision documented

Gate 8 - Production readiness

- External security testing and remediation complete
- Reliability objectives based on pilot usage established
- Legal, privacy, support, and commercial operating processes ready
- Production launch decision approved

16. Out of scope for the first production pilot

- A proprietary vector database or novel memory-retrieval algorithm
- Silent capture of complete conversations
- Consumer social or relationship memory
- Marketplace of third-party context providers
- Automatic synchronization with native vendor memory

- Custom model training
- Fully autonomous context writes
- Mobile-native applications
- Broad public launch before a controlled enterprise pilot

17. Key risks and responses

Risk	Product response
Existing memory vendors add governance	Focus on cross-vendor policy, purpose limitation, employee visibility, and evidence interoperability
AI tool writes poisoned or incorrect context	Proposal quarantine, provenance, validation, human review, versioning, and rollback
Product becomes employee surveillance	No productivity scoring, content-minimized evidence, employee visibility, and explicit governance charter
Vendor integration changes	MCP-first contracts, adapter isolation, capability registry, and conformance tests
Policy rules become unusable	Structured defaults, simulation, explainable decisions, and progressive disclosure
Audit log is altered by privileged operators	Append-only storage plus externally anchored integrity checkpoints
Legal claims exceed actual rights	Treat GDPR portability as scoped; do not claim an EU AI Act memory-portability mandate

18. Open decisions requiring validation

1. First design-partner industry and regulatory environment
2. Whether the employer or employee owns each organization-context category
3. Default approval threshold for low-risk tool proposals
4. Customer-managed keys at pilot or after pilot
5. Required evidence retention periods
6. Whether personal passports are offered inside an enterprise tenant or remain a later consumer product
7. Commercial packaging: platform fee, active user, connected client, or evidence volume

19. Current project record

Completed

- Installed the requested development and product-design skills
- Inspected the original thirteen-page PRD and architecture diagram
- Completed primary-source vendor, standards, security, and regulatory research
- Identified twelve product, buyer, control, delivery, and career-aligned personas
- Corrected the positioning and regulatory narrative
- Established the Nomad design system
- Produced the revised PRD and milestone framework

Built in this iteration

- Clickable three-variant interface prototype
- Employee and administrator navigation model
- Interactive approval, access, activity, and policy examples
- Presentation-ready PRD PDF with UI mockups

First production work after prototype selection

1. Freeze terminology and domain contracts.
2. Write the threat model and authorization decision table.
3. Create the production repository structure.
4. Implement tenancy, identity, schema migrations, and policy enforcement tests.
5. Add the first employee passport workflow.
6. Add the generic MCP integration and contract tests.

20. References

- Model Context Protocol: [official source](#)
- MCP authorization: [official source](#)
- OpenAI MCP guidance: [official source](#)
- Anthropic remote MCP connectors: [official source](#)
- Gemini function calling and remote MCP: [official source](#)
- Microsoft Copilot Studio MCP: [official source](#)
- GDPR Article 20: [official source](#)
- EU AI Act: [official source](#)
- OWASP LLM01 Prompt Injection: [official source](#)

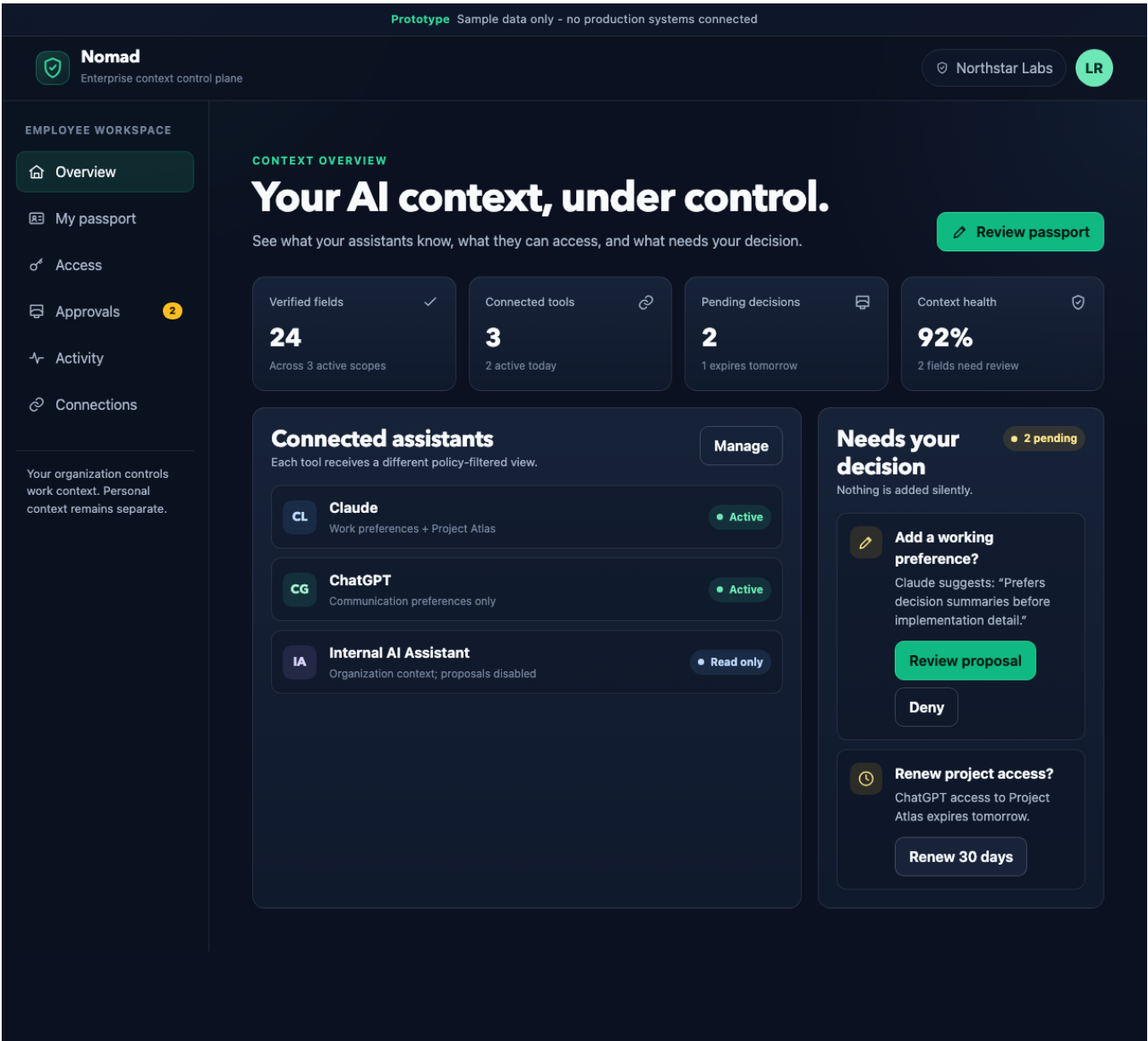
- NIST AI Risk Management Framework: [official source](#)

Interface directions

Three structural directions were built to test product hierarchy. They use the same sample data but optimize for different primary users. The production interface should use Direction A as the shell, Direction B for passport detail, and Direction C for evidence and policy administration.

Direction A - Control Center

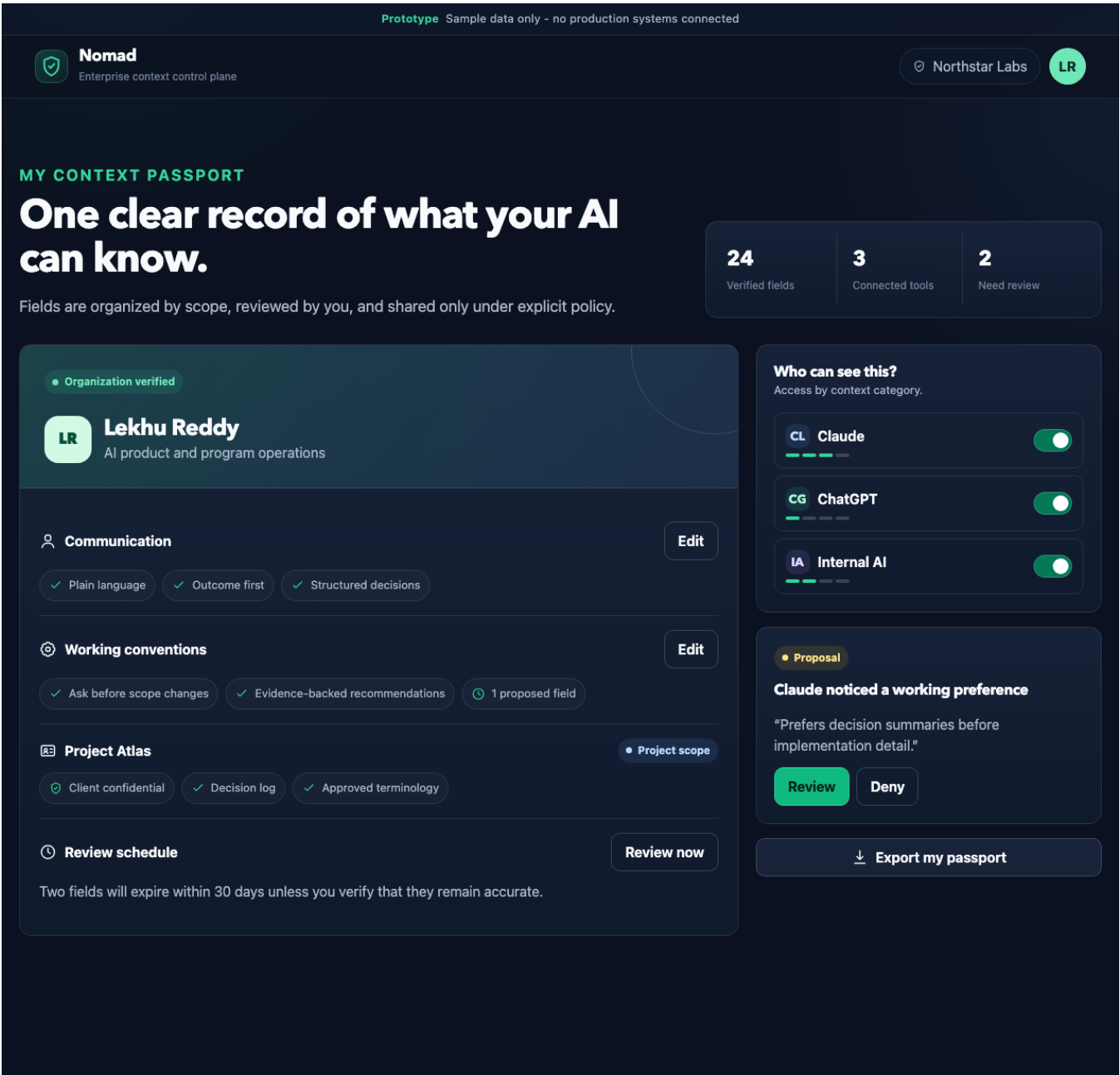
Balanced employee workspace with status, connected tools, approvals, and a persistent navigation model.



Recommended shell: strongest balance between employee clarity, extensibility, and administrator navigation.

Direction B - Passport First

User-centered passport view that makes context ownership, categories, and tool visibility tangible.



Recommended detail pattern: makes user ownership, provenance, visibility, and context health understandable.

Direction C - Evidence Ledger

Administrator-first view optimized for policy posture, investigation, and audit evidence.

Nomad

Enterprise context control plane

Northstar Labs

LR

ADMINISTRATOR WORKSPACE

Evidence before assumptions.

Investigate every context decision without exposing unnecessary field values.

1,284

Decisions today

98.7%

Allowed by policy

11

Denied requests

4

Awaiting review

0

Integrity gaps

Context evidence ledger

Plaintext values are excluded from event records.

Filters

EVENT	ACTOR / CLIENT	SCOPE	POLICY RESULT	TIME
Context read evt_8F12	Claude / Lekhu R.	Project Atlas	Allowed	09:42:18
Write proposal evt_8F11	Claude / Lekhu R.	Work preferences	Review	09:41:54
Context read evt_8F10	ChatGPT / Lekhu R.	Client Omega	Denied	09:39:07
Grant revoked evt_8F0F	Admin / Sarah K.	Organization	Applied	09:31:23
Context read evt_8F0E	Internal AI / Mateo G.	Organization	Allowed	09:27:41

Policy posture

Rules evaluated outside the model.

Simulate

Client isolation

Enforced

DENY when request.client_id != context.client_id

Sensitive proposals

Enforced

REVIEW when sensitivity in [confidential, restricted]

Project expiration

4 expiring

EXPIRE grant 30 days after project_end

External assistants

Enforced

ALLOW read only when tool.approved && purpose.declared

Open policy builder

Recommended administrator pattern: dense evidence presentation without duplicating sensitive context values.

Nomad PRD v2.0

18